Auditing & Monitoring Databases: A Proactive Approach for Better Security

Garrett Bates

AMU (Dept. of Cybersecurity)

ISSC290: Securing Databases

Dr. Margaret Rutter Foltz

5/4/2023

Abstract

As data breaches and cyberattacks continue to pose significant threats to organizations, database security has become increasingly critical. It is interesting when one examines & analyzes the effectiveness of auditing and monitoring for enhancing database security. After reviewing some current practices recommended for security purposes and for evaluating a range of auditing and monitoring techniques, my findings indicated that a comprehensive approach to database security that includes both *auditing and monitoring* has the potential to significantly reduce an attack surface while decreasing the risk of data breaches and improving compliance with data privacy regulations. Additionally, understanding the importance of implementing auditing and monitoring procedures with other security measures, such as access controls, and SQL Injection prevention will provide a more robust security position for a company. The research conducted in this paper demonstrates the value of auditing and monitoring in strengthening database security and provides practical guidance for organizations & individuals alike seeking to improve their database security position.

Keywords: database, security, auditing, monitoring, SQL Injection, access controls

Table of Contents

Introduction ……………………………………………………………………………………4

Database Auditing & Monitoring ………………………………………………………….....5

Auditing ……………………………………………………………………………..5

Monitoring …………………………………………………………………………..5

Continuous Auditing & Monitoring: Preventing Attacks ……………………………………..6

SQL Injection ………………………………………………………………………6

Fun Fact ……………………………………………………………………………..7

Catastrophic Consequences ……………………………………………………………………7

Equifax Breach ……………………………………………………………………...8

Access Controls ……………………………………………………………………..8

The POLP …………………………………………………………………………...9

Conclusion ……………………………………………………………………………………..9

Further Thoughts ……………………………………………………………………9

References ……………………………………………………………………………………11

Introduction

In this research paper, I will be going over auditing and monitoring a database. Then discussing why *monitoring* can be vital to database security as well as how *auditing* helps system admins. I will also be attempting to provide a concise understanding of what each is and how they go together like peanut butter & jelly. Next, I will share my thoughts on *continuous* auditing and monitoring and how it can contribute to preventing *SQL injection*. Additionally, details will be provided on the importance of *complying with regulatory policies* and incorporating *access controls* within a company's database environment. I will also be delving more into what catastrophic consequences could occur for a company if they disregard proper security measures in reference to auditing and monitoring. This paper will also examine the importance of access control features and the *principle of least privilege* (POLP). Finally, I will give a brief overview of what was discussed and provide a conclusion as to why database monitoring and auditing are imperative to an organization's business continuity and successful capabilities in securing its database environment.

Database Auditing & Monitoring

Before going any further, I think it's a great idea to get a refresher on what a database is. A *database* can simply be defined as a collection of data or information that is structured and organized on a computer system in a certain way. Databases can be used to complete work tasks, store important information and retrieve that information. A Database Monitoring System (DBMS) such as MySQL is a type of software used to manage, organize, and modify data. But they can also be used to audit & monitor a database, which is what I will be explaining next.

Auditing in a database can be referred to as tracking and recording (documenting) events in a DBMS. Auditing is important for several reasons ranging from "user access and authentication to protecting database objects which are used to hold user or company data and even documentation on defining the functionalities of a system" (Yehuda, 2021). As you can imagine this leads to increased levels of protection in company data and overall security within an organization. Auditing can help system admins track records allowing them to quickly identify and solve issues and increase system performance. A friendly tip is one of the most popular solutions for database audits is MySQL Enterprise (free) Audit, one of the reasons this is a popular auditing solution is that it's free and has a somewhat "user-friendly" experience.

Monitoring in a database environment refers to the procedure of real-time checking on the performance, reliability, and utilization of the database. Monitoring is just as essential as auditing in a database environment. This is because it involves continuously tracking activities and protecting data while verifying threats for administrators to act on accordingly. Without monitoring, vital data stored within a database could be exploited. Auditing & Monitoring go together like peanut butter and jelly not only because it sounds proficient in terms of database security but because they're essential components to hardening a database by providing compliance, performance, and even business continuity which I will go over more later in this paper.

Continuous Auditing & Monitoring: Preventing Attacks

Now that we (hopefully) have a solid understanding of what database auditing and monitoring are, let's talk about *continuous* auditing & monitoring. Continuous auditing and monitoring are good in many scenarios. However, I believe it's important for organizations and IT professionals alike to consider the performance impacts, cost, complexity, and especially the false positives of implementing continuous monitoring. Continuous *monitoring* is just like monitoring except continuous monitoring uses machine learning which in turn uses automated processes to complete certain tasks when auditing and monitoring. For example, continuous monitoring can administer your attack surface while pointing out insufficiencies, it even "ensures you're compliant with certain standards such as the NIST or National Institute of Standards of Technology" (Reciprocity, 2021). Continuous *auditing* allows admins to gather the information they need for compliance conclusions, and it does a lot of the dirty work for database admins such as sampling a percentage of transactions for financial institutions. Continuous auditing and monitoring can be a handy tool for preventing SQL injections as well.

SQL Injections or structured query language injections are a type of attack where attackers attempt to "inject" SQL commands into a public-facing form such as logins. There are different kinds of SQL injections, each having its own specified purpose for an attack yet pertaining to gaining unauthorized access in some way. "They [the attackers] do this in hopes they will be granted access to the data stored within an underlying database" (Brooks, 2018). Thankfully SQL Injection attacks are some of the most preventable cyber-attacks out there. This is awesome because some of the continuous monitoring and auditing features that organizations use already prevent SQL Injection attacks by detecting abnormal user behaviors, providing real-time alerts, and keeping a company in compliance with organizational standards such as the NIST.

One fact that I found interesting when researching SQL injections is that hackers will look for a single quote exploit on login forms. It didn't make sense to me at first, but this essentially means that the form is more vulnerable to SQL injection since single quotes are used to delimit certain values in SQL statements. If the input isn't properly configured a single quote (SQL injection) entered a form can be misinterpreted as a valid SQL command, thus allowing the attacker access to data on a database. Some ways programmers and database admins alike can easily prevent this is by "Always quoting numeric input fields or only allowing input characters from a whitelist to be entered" (Brooks, 2018). This is because single quotes would not be allowed on that whitelist. To further elaborate on what a whitelist is, it's an approved list of trusted items and can be an important tool in cybersecurity when dealing with database auditing and monitoring.

Catastrophic Consequences

Have you ever done something that might have had some sort of possible consequence? It could have been as simple as forgetting to bring sunscreen to a beach, the repercussions would be suffering a possible sunburn. Or leaving your car unlocked when running into a grocery store to pick up a couple of items "really quick", yet you ultimately left your car vulnerable to a possible experienced carjacker or a thief. One thing you don't want to do is disregard good cybersecurity practices when it comes to monitoring and auditing a database. If not properly maintained, meaning mishaps aren't being reported, the staff isn't as educated as they should be, and tasks aren't getting done properly, then detrimental things can happen, and not only could your company suffer but there could be potential job loss.

Data breaches are a huge issue today and they have been for some time. Businesses around the world suffer from these breaches and damage to a company's reputation and impairment with clients as far as business continuity is sure to occur depending on the severity of the breach. One real-world example of this was the Equifax breach of 2017. I chose this example simply because it's one of the more popular data breaches that occurred. According to the Federal Trade Commission, in 2017 Equifax announced a data breach *exposed the personal information of 147 million people*! Equifax complied with the Federal Trade Commission on a $425 million settlement to assist people that were ultimately affected by the breach. This goes back to one of the many consequences of possible consequences that could occur when met with insufficient database monitoring and auditing. No one should want a data breach to occur, in the end not only did Equifax lose money but they lost clients. Thankfully, there are many ways to mitigate data breaches.

Even though there are many ways to prevent data breaches one awesome way to mitigate data breaches and reduce an attack surface is to implement access control features. *Access controls* can also be referred to as security measures put in place to limit access to certain sensitive information, limiting access is great for admins as well because then you know who has access to what, thus reducing the risk of a data breach from insider threats, unauthorized access all around or even misuse of data. This relates to database auditing and monitoring because access controls can be set up within a database and allow administrators to see who can access what kinds of data thus, they can also potentially monitor who is attempting to bypass them. I would also like to note that it's a good idea to simplify access permissions. "When complex workflows are in place for granting access permissions, it becomes challenging to monitor each user's level of access. As a result, it becomes much simpler to mistakenly provide a user with greater access than they need" (Kost, 2023).

The Principle of Least Privilege, in my opinion, is the security principle to have in an organization. It essentially reiterates the importance of providing users with grants and permissions of only the levels required to do their job roles. Implementing this principle in any organization can significantly help protect a company from damage inflicted in the case of a security breach.

Conclusion

Overall, I have covered several important topics relating to database security. After brushing up on what a database is, I discussed the differences between auditing and monitoring and how they complement each other to provide a comprehensive security strategy. I also investigated further into the concepts of continuous auditing and monitoring, including the procedures involved throughout implementation, and I even highlighted the importance of preventing SQL injection attacks, implementing access controls, and following the principle of least privilege (POLP).

Furthermore, I emphasized the potentially catastrophic consequences that companies could face if they fail to meet certain standards and disregard best practices when auditing and monitoring their database. Companies must prioritize database security by implementing vigorous auditing and monitoring procedures, this will ensure business continuity and employee/client satisfaction is guaranteed. It still makes one wonder how many companies out there aren't following the best practices for auditing and monitoring their databases. However, by confirming that a company's staff is properly trained and aware of the associated risks involving auditing and monitoring, I would consider that company to be ultimately prepared, ready, and eventually successful when working with database security.

References:

Lineup. (2022, March 9). *3 reasons you should audit your database regularly*. Lineup. Retrieved April 11, 2023, from https://lineup.com/blog/audit-database-regularly#:~:text=Auditing%20your%20databases%20enables%20you,it%20to%20an%20audit%20trail.

Reciprocity. (2021). *Continuous auditing vs. Continuous Monitoring — riskoptics - reciprocity*. Continuous Auditing vs. Continuous Monitoring. Retrieved April 11, 2023, from https://reciprocity.com/continuous-auditing-vs-continuous-monitoring/

Basta, A., & Zgola, M. (2011). Database Security. Cengage Limited. https://online.vitalsource.com/books/9781305328495

Brooks, C. J., Grow, C., Craig, P., & Short, D. (2018). *Cybersecurity Essentials*. Sybex a Wiley Brand. https://www.amazon.com/Cybersecurity-Essentials-Charles-J-Brooks/dp/1119362393/ref=sr_1_1?crid=SHODH70O2VKD&keywords=Cybersecurity+Essentials&qid=1683240132&sprefix=cybersecurity+essential%2Caps%2C227&sr=8-1

Yehuda, Y. (2021, November 28). *Database audits: Why you need them and what tools to use*. DBmaestro. Retrieved May 4, 2023, from https://www.dbmaestro.com/blog/database-compliance-automation/database-audits-tools

Kost, E. (2023). *6 most common causes of data leaks in 2023: Upguard*. RSS. Retrieved May 4, 2023, from https://www.upguard.com/blog/common-data-leak-causes

Vedova, H., & Technology, T. F. T. C. O. of. (2022, December 20). *Equifax Data Breach Settlement*. Federal Trade Commission. Retrieved May 4, 2023, from https://www.ftc.gov/enforcement/refunds/equifax-data-breach-settlement